

API Security Assessment Report Read Only Security of Public Demo API

Analyst: Busisiwe Ngoma

Date: 09/02/2025

Tools used: Postman, Documentation references

Method: read only API inspection

Executive summary

This assessment reviewed a public facing application programming interface (API) using read only testing methods to identify potential security risks. The goal was to understand how the API handles user data, access control, and request activity, and to highlight any weaknesses that could affect a real business environment.

During testing, several security concerns were identified. The API allowed access to user information and related data without requiring authentication. It was also possible to retrieve records belonging to different users by modifying request parameters. Large data sets, including posts and comments, were accessible publicly, and email information was visible within responses. In addition, repeated requests to the API were accepted without restriction, suggesting limited protection against automated abuse.

While this environment is intended for testing and learning purposes, the behaviors observed reflect common risks seen in real SaaS platforms. If present in the production system, these issues could lead to data exposure, privacy concerns, and misuse of the platform.

This report outlines the key findings, explains the business impact in simple terms, and provides practical recommendations to help organization strengthen API security and reduce risks.

Scope of assessment

This assessment focuses on analyzing a publicly accessible demo API using safe, read only methods. The testing was limited to reviewing how the API responds to requests, what data is exposed, and whether basic security controls such as authentication and request restrictions are in place.

No intrusive testing, exploitation, or system modification was performed. The assessment only involved sending standard requests to available endpoints and reviewing the responses returned by the system.

The review specifically reviewed:

- Access to user profile
- Exposure of posts and comments
- Authentication and authorization behaviour
- Data returned in API response restrictions

This assessment reflects the type of high level security review commonly performed during early stage SaaS security testing or internal risk assessment.

Methodology

This assessment was conducted using a structured, step by step approach to understand how the API behaves when accessed by the general user without authentication.

The process included:

- Reviewing publicly available API endpoints
- Sending read only GET requests using postman
- Inspecting response data returned by the API
- Checking for authentication requirements
- Observing headers and request behaviour
- Testing access to different user records by modifying request parameters
- Reviewing how much data is returned in a single request
- Repeating requests to observe whether any rate limiting controls were applied

This approach mirrors how security analysts perform initial API risk assessments in real world environments, focusing on identifying exposure risks without disrupting systems.

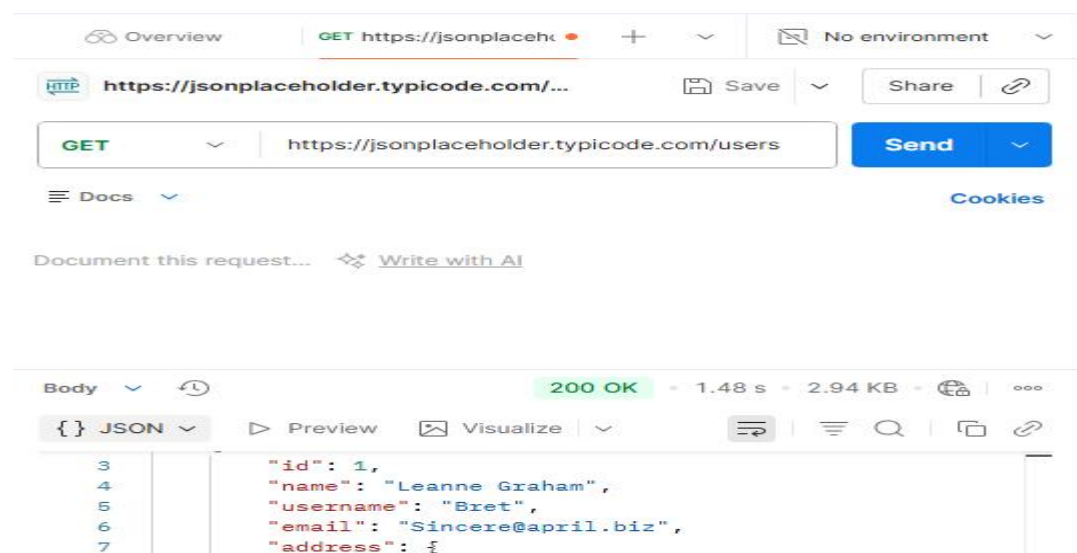
Tools used

The following tools were used to perform the assessment:

- Postman - to send API requests and inspect responses
- Documentation references - to understand available endpoints and expected functionality

These tools are commonly used by security analysts and developers to review API behaviour and identify potential risks in a controlled and safe manner.

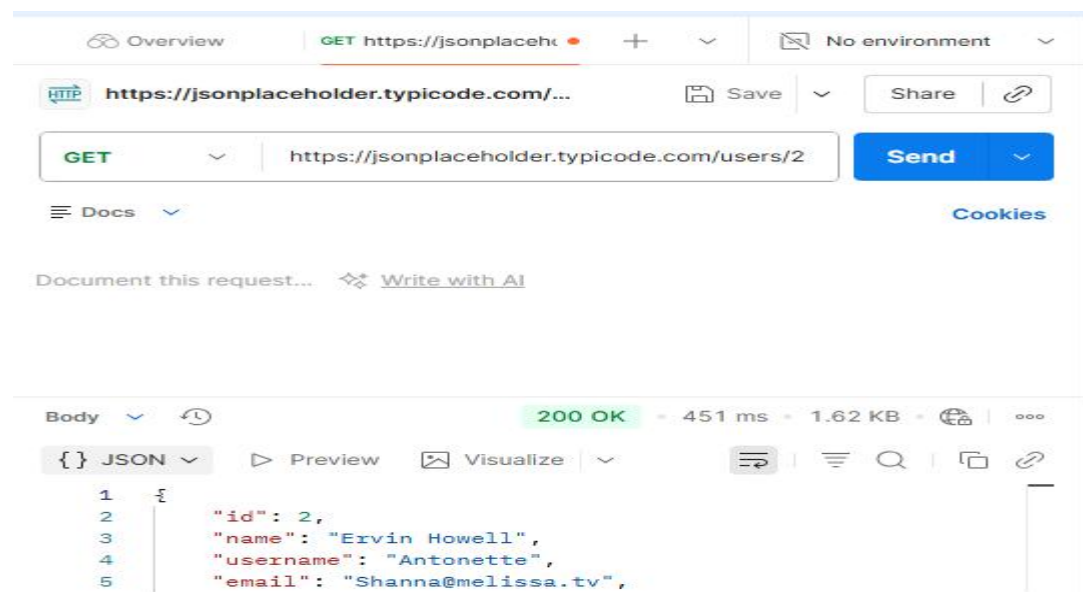
Findings and risk ratings



1. Unauthenticated access to user data risk level: High

The API allows public access to user profile information without requiring any form of login or authentication. Personal details such as names, email addresses, phone numbers, and company information are visible in the response.

In a real business environment, this could expose sensitive customer data and increase the risk of privacy violations and reputation damage

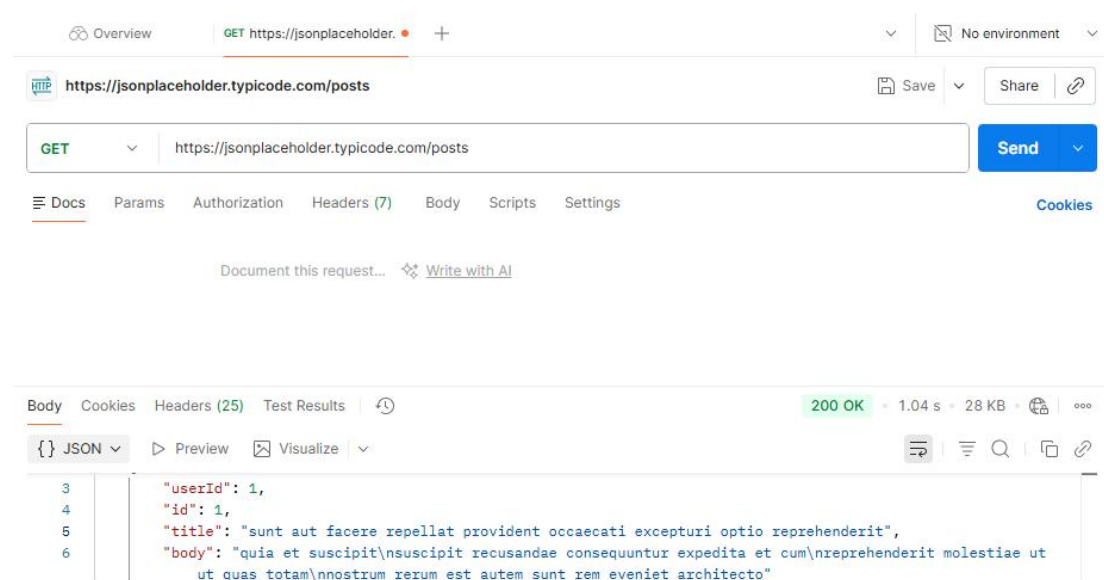


2. Broken Object Level Authorization (Accessing Other User's Data)

Risk level: high

By changing the user ID in the request, it was possible to access the profiles of different users without restriction. This indicates weak access control and a lack of verification to ensure users can only view their own information.

In a production system, this could allow attackers to browse or extract data belonging to the other customers.

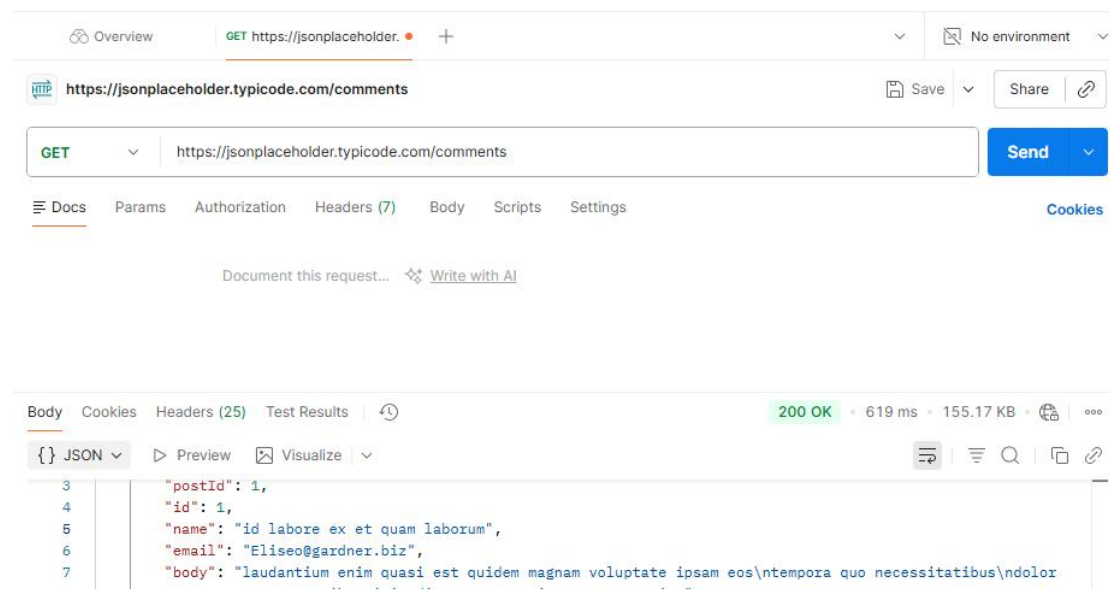


3. Excessive data exposure through posts endpoint

Risk level: Medium

The API returns large collections of posts linked to multiple users in a single request. This makes it easy to gather and analyze platform data without any authentication.

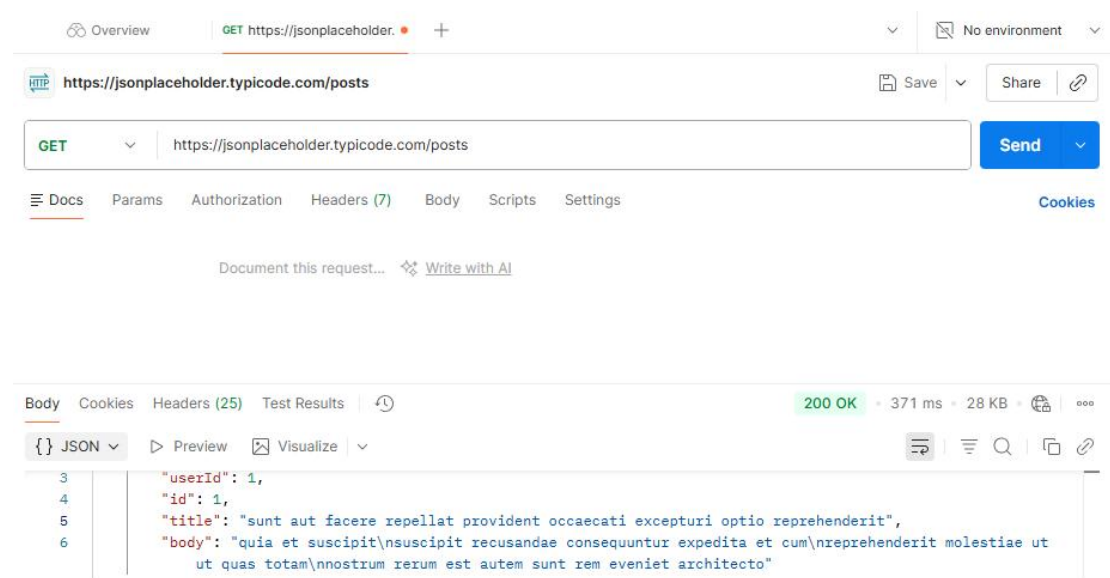
This behaviour could support data scraping, competitive intelligence gathering, or misuse of platform content.



4. Exposure of comments and email information

Risk level: high

The comments endpoint reveal user-linked data, including names and email addresses, without restrictions. This information can be used for phishing campaigns, spam, or target attacks.



5. Missing rate limiting controls

Risk level: Medium

Repeated requests to the API were accepted without any blocking or warning. This suggests the absence of visible protection against automated or high volume requests.

In real systems, this can lead to data scraping, service abuse, and performance issues.

Business impact

If these issues were present in a real SaaS environment, they could have serious consequences for both the organization and its users.

Unauthorized access to user data could lead to privacy breaches and loss of customer trust. Exposure of email addresses and personal information increases the risk of phishing attacks and spam campaigns targeting users. Weak access control may allow individuals to view or extract data belonging to other customers, creating legal and compliance concerns.

The ability to retrieve large data sets without restriction also opens the door for data scraping and misuse of platform content. In addition, the lack of request limits may allow automated traffic to overwhelm systems or extract large amounts of information in a short time.

Together these risks could result in reputation damage, regulatory penalties, operational distribution, and loss of user confidence in the platform.

Remediation recommendations

To reduce the risks identified during this assessment, the following actions are recommended:

Require authentication for sensitive endpoints

User data, posts, and comments should only be accessible after proper login and identify verification. Public access to personal or account-related data should be restricted.

Implement strong access control

Users should only be able to view or interact with their own data. The system should validate every request to ensure that data belonging to other users cannot be accessed by changing IDs or parameters.

Limiting data returned in API responses

APIs should return only the minimum information required for functionality. Sensitive fields like email addresses, phone numbers, and internal identifiers should not be exposed unless necessary.

Introduce rate limiting and request monitoring

Systems should detect and restrict repeated or automated requests to prevent scraping, abuse, and system overload.

Apply input validation and monitoring

Requests should be monitored for unusual behaviour, and input should be validated to reduce the risk of manipulation or abuse.

Regular security reviews and testing

APIs should be reviewed periodically to identify new risks, ensure controls remain effective, and maintain secure development practices

Conclusions

This project demonstrated how log analysis and monitoring can be used to identify potential security threats and suspicious login activity within a system. By analyzing event login attempts and authentication events, it became possible to detect behaviour that may indicate unauthorized access or security weaknesses.

This exercise also highlighted the importance of using security tools like SIEM platforms to centralize data, improve visibility, and support faster incident detection and response. Overall the project strengthened practical skills in log analysis, threat identification, and basic incident investigation, which are essential in real-world cybersecurity environments